

KESSEL RUN



**Task Order (TO) 0001
Performance Works Statement (PWS)
for
All Domain Common Platform (ADCP)
Security Cloud Engineering Network Development
(ASCEND)**

Revision 2.0 – 15 January 2025



Air Force Life Cycle Management Center/Kessel Run
(AFLCMC/C3C)
11 Barksdale Street
Building 1614
Hanscom AFB, MA 01731-1700

TABLE OF CONTENTS

1.0	Purpose
2.0	Period and Place of Performance
3.0	Performance Objectives
	4.1 Platform Architecture and Systems Engineering
	4.2 Cloud, Cloud Edge, and Infrastructure
	4.3 Platform Engineering and Operations
	4.4 Platform Cybersecurity Engineering
4.0	Operating Constraints
	5.1 Transition Plans
	5.2 ADCP Technical Baseline Management
	5.3 Product Roadmaps
	5.4 Surge Capacity
5.0	Data Deliverables
6.0	Service Delivery Summary

1.0 PURPOSE:

The purpose of this TO specific PWS is to provide the contractor with ADCP's current requirements for supporting enterprise level cloud activities. The Government will utilize this document to emphasize to the contractor the Government's intent and desired end-state for this specific workstream.

All work shall be performed by the contractor in accordance with the Indefinite Delivery/Indefinite Quantity (ID/IQ) Performance Works Statement (PWS) and supplemental requirements provided in this Task Order (TO) PWS.

2.0 PERIOD AND PLACES OF PERFORMANCE:

The period of performance for this TO will be a base period of one (1) year, followed by four (4) option periods of one (1) year duration each. However, it is at the sole discretion of the Government whether to exercise any of the option periods associated with this effort.

The primary places of performance shall be Hanscom Air Force Base, Massachusetts and Langley Air Force Base, Virginia. However, contractors may be allowed to perform remotely from locations other than the primary places of performance.

It is anticipated that TOs may be issued that require the contractor to have access to and work with classified materials. In those cases where the TO calls for working with classified materials, the Government may provide classified workspaces for the contractor to perform within.

However, when classified Government workspaces are not available, the contractor shall provide their own classified workspaces accredited to the classification level prescribed within the TO(s) DD Form 254.

The contractor shall be able to meet the following minimum requirements for classified space available to support ADCP critical mission functions.

- Minimum number of seats	45 (40 seats to be staffed eight (8) hours per day from 0800 – 1600 EST)
- Minimum number of seats supporting 24/7/365 operations	5 (this number is included in the minimum number of seats quantity of 45)
- Minimum network connectivity available at each seat:	- Non-classified Internet Protocol Router/Secret Internet Protocol Router (NIPRNet/SIPRNet) with access to Joint Worldwide Intelligence Communication System (JWICS) - Voice Over IP (VOIP)

	- Secure Voice Over IP (SVOIP)
- Minimum Facility Classification Level:	Final Top Secret
- Additional Minimum Requirements:	- Existing Special Access Program (SAP) certified physical space capable of supporting IT operations - Secret open storage or Sensitive Compartmented Information Facility (SCIF) facilities with NIPR/SIPR and JWICS capabilities

NOTE: The minimum number of seats do not all need to be available at one location. Individual TO(s) may require some classified support to be provided in Outside the Continental United States (OCONUS) locations. In those circumstances, the Government will provide the classified spaces for the contractor to perform in.

Prior to engaging in work outside the primary places of performance, the contractor shall receive approval from the Contracting Officer (CO) and Contracting Officer's Representative (COR) for those alternate locations.

3.0 PERFORMANCE OBJECTIVES:

Kessel Run has a requirement to implement and support an accelerated ADCP solution that prioritizes security, availability, scalability, performance reliability, cost optimization, observability, portability, usability, maintainability, agility, flexibility, and operational excellence. These attributes are essential to ensure ADCP is a reliable platform for hosting Command and Control (C2) mission applications during peer competition and conflict.

ADCP will be responsible for the development, fielding and operations of environments for mission critical warfighting applications. The platform and its associated components need to be operationally available and mission capable 24/7/365 and need to be resilient against any peer advisories (cybersecurity, etc.).

The contractor shall develop and deliver and operate a cloud native DevSecOps platform and production environment(s) with rapid code deployment, enterprise solutions (ICAM, etc.) and integrated process and triage capabilities. It will operate across multiple classification levels and shall be developed and operated in a way that uses as much modernized and centralized services and tooling as possible for consistent use and/or delivery across the broader Air Force (AF).

The following sections outline the performance objectives that shall be achieved by the contractor in support of this workstream.

3.1 Platform Architecture and Systems Engineering

The contractor shall be responsible for providing industry best practices, documentation and guidance pertaining to architecture and design. This includes but is not limited to:

- Shall update architecture drawings, runbooks, and documentation to administer and maintain environments. These drawings, runbooks and documents shall be updated quarterly, or as defined by the Government
- Shall implement design with a modular architecture with clear abstractions
- Shall implement “clean architecture” principles of modularity, single responsibility, layering, dependency inversion, extensibility, and clean Application Programming Interface (API) design

The contractor shall be responsible for developing the strategy and design for ADCP’s cloud edge solution.

3.2 Cloud, Cloud Edge, and Infrastructure

The contractor shall provide cloud management, to include but not limited to, manage cloud accounts, Infrastructure as Code (IaC) (e.g. Terraform), Zero Trust, identity access management to Impact Level (IL)4/5/6 and JWICS (Top-Secret). The contractor shall have experience with developing, managing, and automating pipelines for deployment as well as the developer experience via Identity Management in accordance with (IAW) Department of Defense (DoD) Identity, Credential, and Access Management (ICAM) strategy. Further, the contractor shall provide 24/7/365 support of the infrastructure.

AFLCMC/C3C’s goal is to leverage platform tools and services widely used within the DoD and AF for web-based DevSecOps platforms that manage software development, security, and deployment, as well as Identity and Access Management. Whenever possible, solutions from other Department of the Air Force (DAF) Battle Network service providers, to include but not limited to, Advanced Battle Management System (ABMS), Cloud Based Command and Control (CBC2) and DAF Cloudworks, shall be sourced, used, and supported to ensure consistency, alignment, and enablement of potential merges and/or federations including the support of those efforts.

3.2.1 Current Cloud Environments

The current Cloud Services Provider (CSP) is Amazon Web Services (AWS), but flexibility to use other CSPs is required for the future. Multiple functional environments are provisioned including test, exercise or training, staging, and production with the goal of environment parity for rapidly deployed cloud-native applications across ILs and releasability (NOFORN, FVEY, NATO, RELKOREA). Requirements are set forth below assuming that all other ILs maintain feature parity with IL6 and have at a minimum the same tooling and availability. There may be additional needs or requirements at other ILs to be set forth in additional TO(s).

- Environment - IL6 Secret
 - IL6 is the least capable IL. Thus, the IL6 environment is where architecture for AWS services usage is determined. In other words, if a service or feature isn't available in IL6 through AWS, that service and capability shall not be used in other ILs so that consistency is maintained as much as possible across all functional environments and ILs.
 - The contractor shall deliver, maintain and operate a reliable, resilient, and highly available 24/7/365 Secret implemented cloud environments to include:
 - Tools
 - Observability & SIEM
 - General Services
 - Sandboxes
 - Staging
 - Production
 - Environment builds to be fully automated via Infrastructure as Code (IaC) and in full parity with IL4, IL5, and Top Secret (JWICS).

- All Environments
 - Shall be managed via Infrastructure as Code (IaC)
 - Shall have consistent architecture in every AWS Solution possible with the Lowest Common Denominator (LCD) set at IL6 (or the lowest capable environment) for environmental parity
 - Shall be administered by personnel cleared per guidance in DoD Manual (DoDM) 8140.03
 - Shall have backup, recovery, and disaster recovery tiers for respective environments as needed
 - A staging environment shall be used to support pre-production deployment and “smoke testing” of a new version of the code before it is deployed into other environments (Production, Exercise, & Training).
 - Cost shall be a factor in not overprovisioning development environments. Thus, less Availability Zone (AZ) usage, burst instances, and even reserved instances (RIs) are acceptable to keep costs low. Scaling down development and test environments when not used shall be practiced whenever possible.
 - The contractor shall ensure consistent implementation of cloud Financial Operations (FinOps) in accordance with organization policies, practices, and objectives.

- The contractor administrators shall have the ability to shut down and spin up both primary and Continuity of Operations Plan (COOP) environments on demand as needed
- Exercise/Test/Training Environments
 - Test environments may be required at times for a long living feature or to run operational testing. These environments shall be deployed in development or staging environments only and shall not require their own cluster and Big Bang in each region. These environments shall not require corresponding COOP environments in case of outage.
 - Exercise or Training Environments may be required at times for real world exercises or for application training. These environments shall be deployed in staging environments only and shall not require their own cluster and Big Bang.
 - An Exercise environment shall be spun up temporarily to support an Exercise (typically 2-14 days) and then be destroyed.

3.2.2 Cloud Edge

The contractor shall continue to develop new features, operate and maintain the given cloud edge solution as set for in subsequent TO(s). If there is an existing solution by the time this contract is in effect, then the contractor shall be responsible for the operation and maintenance of the infrastructure, architecture and software for the cloud edge.

3.2.3 Infrastructure

The contractor shall implement infrastructure according to best practices, including IaC. The contractor shall be responsible for the implementation, feature development, operations and maintenance of such infrastructure.

- Infrastructure as Code (IaC)
 - All cloud-related changes that can be controlled shall be code-controlled, revisioned, transparent, and change-controlled.
 - All IaC shall be promoted up environments so that configuration and management can remain consistent across ILs.
 - IaC shall be released to environments via pipelines and require authorization from a release authority via Government approved release processes.
 - Disparate IaC shall be consolidated into a functioning model of modules of organization so that entire environments can be deployed to new regions with minimal setup and orchestration.

3.3 Platform Engineering and Operations

ADCP is responsible for developing, running, maintaining and operating the platform used to develop and deploy warfighting applications. The contractor shall perform the following:

3.3.1 Sustainment of Existing ADCP Baseline:

ADCP plans to migrate all workloads running on the Tanzu Platform to a Kubernetes Platform running on AWS infrastructure. Should migration not be completed by the start date of this TO, the contractor shall deliver the final migration to the cloud of any remaining workloads and ensure zero disruption to existing operations (except for planned outages/ASIs/COOPs/etc.) and a roadmap for the efficient migration of remaining workloads to the Kubernetes-based cloud environment.

The contractor shall focus on supporting the operations of applications and services that rely on the current platform and collaborating with other platform teams to ensure efficient and successful transition of any remaining workloads from on-premises platforms into the cloud. If on-premises systems must remain the contractor shall continue to support those operations, maintenance and 24/7/365 support.

In support of this requirement, the contractor shall develop a product roadmap outlining the remaining migration activities to be conducted and a product backlog identifying those workloads still to be migrated.

CDRL A011 Product Roadmap / DI-IPSC-82297

CDRL A012 Product Backlog / DI-IPSC-82298

3.3.2 Software Development

- The contractor shall establish a common Integrated Development Environment for developers to create, compile, and debug code.
- The contractor shall be able to perform local development of code via a Kubernetes framework, such as Docker-Compose, KinD, Docker Desktop or other similar tools that are Government approved.
- The contractor shall establish a “pilot light” pre-development environment into Kubernetes where developers can get fast feedback on changes in an application or ecosystem (such as KRADOS) prior to the SECREL pipeline.
- The contractor shall provide the ability to scan and analyze code as developers create them so that software assessments can be performed to identify potential weaknesses and vulnerabilities and provide remediation solutions.
- The contractor shall provide a repository for source code and other software artifacts to support collaboration, configuration management, branching, merging, and build traceability.
- The contractor shall provide a tool to assess code quality, including code changes, defect identification, change management, and collaboration.
- The contractor shall provide access control and administration for all Big Bang

tools.

- 100% of code, whether IaC, Big Bang, or other supporting software shall be stored in a code repository, be revisioned, change controlled, and be controlled by KR/AFLCMC/C3C, and visible to its partners, when necessary.
- Any vendor-specific Intellectual Property (IP) shall be decoupled from all other code so that future changes to projects keep any platform, software, or service under the Government's control.
- In the event that contracts do not continue by either party, there shall be a mechanism for the Government to retain control of the platform, software, or service supporting all Government applications and tools.
- The mechanism to retain control of platform, software, or services supporting all Government applications and tools shall include training of applicable Government personnel to a level where there is zero disruption to Warfighter applications and operational support.
- Upon request, the contractor will provide the Government with a Portability Plan IAW Contract Data Requirements List (CDRL) A001. Specifically, the Portability plan shall identify, in the form of user instructions, the complete set of processes and procedures that are necessary to extract all of the Government's data, without restrictions or dependencies, imposed by the contractor.

CDRL A001 Portability Plan / DI-NDTI-80603A

3.3.3 CI/CD Orchestration

- The contractor shall set up, configure, manage, and support 24/7/365 CI/CD pipelines workflow and execution compliant with AFLCMC/C3C's Authority to Operate (ATO) as documented in AFLCMC/C3C Continuous Authorization Risk Management Playbook.
- All pipelines shall deploy software via an approved security scanning pipeline based on a capability's matrix provided by AFLCMC/C3C security.
- All Cross Domain Solutions (CDS) recommended for use by the contractor shall require security approval.
- Developers shall be trained to deploy, troubleshoot, and rollback their own deployments via the industry model of responsibility, including blue/green deployments.
- All pipelines shall be revisionable, transparent, and change controlled.
- The contractor shall assist the Government with the existence of an automated auto-deployment process to deploy applications (post CDSAWS Diode) up to Top-Secret environments. (e.g. ArgoCDd/Fleet/Flux)

3.3.4 Path to Production:

- The contractor shall develop and maintain a full path to production to include developer/development tools approved under the continuous Authority to Operate (c-ATO) and fully automated CI/CD pipelines (to meet all requirements necessary for c-ATO) from the unclassified development environment to Top-Secret environments.
 - Development shall be undertaken in unclassified or secret and deployed to the IL5, IL6, and/or Top-Secret (JWICS) environment.
 - Security scanning and release pipelines shall be able to manage internally developed applications, 3rd party applications for which source code may be unavailable, multi-image deployment, ability to build and release software comprised of multiple components in a single pipeline execution, and Version Control for respective applications.
- The contractor shall be responsible for all maintenance, upgrades, updates and support (hardware and software) in all environments in compliance with ATOs, c-ATOs, to include any required credentials and access to Secret and Top-Secret environments.
- Security scanning release pipelines shall be secure and c-ATO compliant, and conform to policies/regulations/standards as required by AFLCMC/C3C security (to include both security and end-to-end pipeline run times as criteria). To include:
 - Shall use an appropriate access control scheme (RBAC, ABAC, etc.) to achieve separation of duties and the principle of least privilege.
 - Shall provide a “shared responsibility” type delineation of security responsibilities between product owners and product users/consumers.
 - Shall provide documentation on security best practices for product users/consumers.
 - Shall ensure all major third-party components must have an active approval/authorization.
 - Shall ensure that the overall system/program is regularly reviewed and assessed at medium or lower risk to the organization.
 - Shall enable deployments via IaC and Configuration as Code (CaC), as appropriate for the artifact type.
 - Shall verify all component signatures at deployment.
 - Shall ensure that service accounts cannot be assumed by human users.
 - Shall maintain dependencies up to date.
 - Shall perform testing and review of changes before production deployment.
 - Shall apply appropriate Security Technical Implementation Guides (STIG) to the highest degree possible.

- Shall apply appropriate Center for Internet Security (CIS) benchmarks to the highest degree possible.
- Shall use automation to scan for vulnerabilities and apply relevant fixes.
- Shall perform safe error handling.
- Shall use a memory safe language.
- Shall perform appropriate input validation and sanitization.
- Shall ensure that merges undergo a code review and/or produced via pair coding.
- Shall produce signed artifacts.
- Shall follow Test Driven Development.
- Shall perform static and dynamic code analysis.
- Shall make efforts at attack surface reduction (i.e., by using a minimal base image).
- Shall have a mechanism/channel for reporting security issues and a policy for responding to and remediating reports.
- Shall have host-based protections (Endpoint Detection and Response (EDR), Host-Based Intrusion Detection System/Host Intrusion Prevention System (HIDS/HIPS), etc.).
- Shall maintain and rotate keys.
- Shall use process isolation.
- Shall perform file integrity checking for critical files.
- Shall use approved first-order components, pull components from approved registries, and perform integrity checking on pull and on deployment for all components.
- Shall provide a capability to scan cloud infrastructure configurations (e.g. helm charts) to find misconfigurations before they're deployed.
- Shall provide a cross-platform anti-malware scanner to detect many types of malware, including viruses.
- Shall evaluate Dockerfile for policy violations.
- Shall perform static code analysis to scan source code and the compiled output (object code, such as an executable or jar) of the application for security vulnerabilities.
- Shall scan docker images for misconfiguration.
- Shall scan project's node lockfile (yarn.lock / package-json.lock) for issues that could be signs of supply chain attacks, e.g. using http or getting packages from untrusted sources.
- Shall generate a Software Bill of Materials (SBOM) and scan all components and dependencies of the application for vulnerabilities.
- Shall scan docker images for compliance to an appropriate baseline (benchmark) ensuring compliance with security policies.

- Shall perform static code analysis to scan the application's source code and compiled output (object code, such as an executable or jar) for Code Quality and Code Security (code smells, bugs, etc.).
- Shall provide unified security and compliance for containers, Kubernetes and cloud. Scans all docker containers, ensuring they comply with AFLCMC/C3C policies and do not have known vulnerabilities.
- Shall implement a capability to ingest SBOMs and monitor for new vulnerabilities from multiple vulnerability databases.
- Shall alert software assessors when new vulnerability is detected in software and report where a vulnerability is located within development and production software.
- Shall track and report usage of libraries and frameworks, applications, containers, operating systems, firmware, hardware, and services across all projects in the AFLCMC/C3C portfolio to Security Branch for assessment and visibility
- Shall ensure configuration management, version control, and traceability of software development and deployment.
- Shall provide continuous integration allowing ability to merge software efforts
- Shall build automation tools to automate the software build process.
- Shall conduct source code analysis to flag errors, bugs, etc.
- Shall provide a capability to analyze quality of code development.
- Shall provide a capability to store and retrieve sensitive credentials from a centralized repository.
- Shall provide a capability to store and retrieve software artifacts from a central repository.
- Shall provide an Identity and Access Management (IdAM) solution that allows for user management, multi-factor authentication, authorization, auditing and compliance checks.
- The contractor shall assist the Government with maintenance of a Cross Domain Solution (CDS) to facilitate the automated transfer of objects/artifacts and data from unclassified environments to Top-Secret environments to support both artifact and data transfer.
- The contractor shall assist the Government with maintaining c-ATO compliant pipelines and developer portal (if necessary) to fully support the deployment and monitoring of applications up to Top Secret production environments to include both cloud and edge.

3.3.5 Observability, Monitoring, and Alerting

The following requirements apply to platforms and applications in all environments.

- All applications shall be connected to AFLCMC/C3C managed observability tools and clusters.
- The contractor shall create dashboards, heatmaps of applications usage and awareness in Kibana or other Government approved dashboard.
- The contractor shall create alerts on metrics required to support application and infrastructure awareness so that issues/misconfigurations/outages notify support staff.
- The contractor shall assist development teams to instrument their applications to get better data in observability.
- The contractor shall assist the Government in ensuring all security required data is ingested into the Security Information Event Management (SIEM) for analysis, alerts, and dashboards.
- The contractor shall assist the Government to ensure observability to support security metrics, dashboards, alerting; and any other SIEM activities.
- The contractor shall configure the platform for logging, monitoring and alerting to manage the performance and health of applications and the platform itself

3.3.6 Operations and Support

- ⌘ The contractor shall provide a 24/7/365 operation center supporting: Network/Platform Operations Center (NOC) providing day-2 operational support. **Day-2 support:** Observability, monitoring, and alerting of platforms and applications in all environments. This location shall support classified work with SIPR access and SVOIP and NIPR and VOIP.
- ⌘ The contractor shall collaborate with the Government to follow a defined Support Process including but not limited to:
- ⌘ A defined tiered support model for platform and supporting services shall be provided, as well as a defined shared responsibility model. e.g., a detailed accounting of support (to include tier-level) that is the responsibility of the contractor, the responsibility of AFLCMC/C3C, and responsibility that is shared.
- ⌘ The contractor shall maintain and improve existing incident detection and reporting automation.
- ⌘ Shall contribute to the existing incident management process using playbooks, failover automation, and rigorous postmortem investigations.
- ⌘ Root Cause Analysis (RCA) for outages shall be required.
- ⌘ Shall sense and respond to customer requests and operational demands as required.
- ⌘ Shall include 24/7/365 support with 15-minute time to keyboard for platform incidents across all classifications during an incident is required.
- ⌘ Shall include 15-minute acknowledgement of a reported incident.
- ⌘ Shall surge to meet 24/7/365 operational requirements during planned on-call

windows, and as required by the Government per mission requirements.

- ∄ Shall include 24/7/365 support for and management of the platform deployed by the contractor to cloud and supporting pipelines.
- ∄ Shall include 24/7/365 support for and management of CSP services and BBaaS platform provided services (e.g., Gitlab, Nexus, Vault, ArgoCD, IdAM/Keycloak, Istio, etc.)

3.4 Platform Cybersecurity Engineering

3.4.1 Platform Security/Cyber Surety

- Solution shall comply with AFLCMC/C3C's cyber surety and security requirements.
- A single sign-on IdAM provider exists for user and service management. Assumption is that this will be provided by Big Bang as a Service (BBaaS) (e.g., Keycloak).
- Solution shall integrate with AFLCMC/C3C's zero-trust requirement.
- Solution shall integrate with AFLCMC/C3C's Identity Aware Proxy.
- Solution shall provide sufficient platform and logging access to enable AFLCMC/C3C's security team to perform any and all necessary security tasks. To include the ability to relay logs to AFLCMC/C3C's SIEM.
- Shall include a Centralized/Consolidated application-level logging for debugging applications and security related issues and incidents.
- Proposed platform and pipeline solutions shall be ATO compliant in order to meet production mission needs. To that end, the platform and pipelines shall not only meet the requirements of an ATO/c-ATO grant but must have an ATO.

3.4.2 Information System Security Engineering

The Contractor shall complete the following tasks as directed by the Government:

- Provide comprehensive support to protect and defend networks and all attached systems by validating configurations and ensuring regulatory compliance with DoD and Air Force directives, policies, and regulations.
- Effectively communicate cybersecurity and information security requirements, standards, and processes to Kessel Run engineering teams.
- Work with the Kessel Run engineering team throughout the development and sustainment process to ensure compliance with appropriate requirements, standards, and processes.

- Support accreditation requests, including pre-planning, and collaborate with Kessel Run engineering teams to ensure that the appropriate basis of estimate (BOE) (e.g. Decision Brief, Architecture Diagrams, Cyber Requirement, Test Plan, etc.) are developed and delivered.
- Support to Authorization and Accreditation documentation and testing efforts to include development of plans, policies, and procedures and ensuring timely submission of accurate accreditation documentation.
- Provide security reviews for configuration change requests and update appropriate certification and accreditation artifacts as applicable.
- Provide policy and procedure recommendations in support of enterprise solution migration and integration efforts.
- Work with technical teams to establish requirements for Security Release (SecRel) 3.0 and 4.0
- Assist with account management processes and collaborate with the Government to identify opportunities to streamline and simplify processes.
- Support the ATO efforts IAW the following:
 - ✧ Risk Management Framework for DoD IT (RMF) process IAW DoD Instruction 8510.01.
 - ✧ Risk Management Framework (RMF) for DoD Information Technology, DoD Instruction 8500.01.
 - ✧ DoD Instruction 5000.02 Operation of the Defense Acquisition System.
 - ✧ Joint Capabilities Integration and Development Systems (JCIDS) Manual.
 - ✧ Public Law (P.L.) 100-235 (Computer Security Act of 1987).
 - ✧ Office of Management and Budget (OMB) Circular A-130.
 - ✧ DoD Directive 5220.22.
 - ✧ DoD 5220.22M and DoD 5220.22-M- Supplemental.

3.4.3 Cybersecurity Vulnerability Analysis - Infrastructure/Platform

The contractor shall complete the following tasks as directed by the Government:

- Support technical implementation of remediation actions for known security vulnerabilities and system misconfigurations during development and sustainment.
- Work with system administrators, developers, and IT staff to prioritize and plan remediation efforts.
- Evaluate the severity and potential impact of identified vulnerabilities based on industry standards such as Common Vulnerability Scoring System.
- Maintain accurate and up-to-date records of vulnerabilities and their remediation status.

- Track, verify, and document the completion of remediation actions to ensure vulnerabilities are addressed.
- Stay current on latest cybersecurity threats, vulnerabilities, and best practices.
- Deliver detailed reports of scan results to the Government, including findings, impacts, and recommended remediation actions.
- Contribute to the development and enhancement of scanning and reporting processes.
- Support monitoring team with incident detection and response.
- Support infrastructure team with security engineering solutions.
- Responsible for SIEM Stand-up and maintenance.
- The contractor shall complete the following deliverables:
 - ✧ Reports of scan results
 - ✧ Documentation of remediation tasks from application and system owners.
 - ✧ Vulnerabilities record (annual or bi-annual review).

CDRL A010 Technical Report – Study/Service / DI-MISC-80508B

4.0 Operating Constraints

4.1 Transition Plans

4.1.1 Base Year Phase-In Transition Period

The Government’s intent is to provide a phase-in transition period of (nominally, pending further review) 90 calendar days, at the end of which the Government will require the contractor to be fully operational, to include properly cleared personnel at the appropriate classification levels, operational contractor-provided workspaces, and availability of all required IT systems/connectivity. The contractor’s transition plan shall include:

- Identification, by name, position, and responsibilities, of each team member on the Transition Team.
- A schedule with detailed tasks, milestones, and completion dates for each activity. Status shall be reported at a minimum of 15 calendar day increments.
- Plan for recruitment, hiring, and onboarding of personnel, to include security clearances and system accesses.
- Description of risks, dependencies, and mitigation measures, as appropriate.
- In addition to status reporting, the Contractor shall present an operations readiness review approximately thirty (30) days prior to the projected operational “go live” date, with updates as required to secure Government approval for the final “go live” decision.

CDRL A014 Phase-In Transition Plan / DI-SESS-82299

4.1.2 Phase-Out Transition Plan

The contractor shall develop a Phase-Out Transition Plan to facilitate the accomplishment of a seamless transition from an incumbent to incoming

Contractor/Government personnel at the expiration of the final performance period. This plan defines actions needed for an effective transition, to include agreed knowledge capture, transition artifacts, and transfer to ensure programmatic and technical continuity. The Contractor shall provide a Transition Out Plan NLT one hundred eighty (180) business days prior to expiration of the performance period. In the event an option is not exercised, the Contractor will provide a transition-out plan at the direction of the Government within a reasonable, mutually agreed-upon timeframe. The contractor shall establish and maintain effective communication with the incoming contractor/ Government personnel for the period of the transition via weekly status meetings and other interactions determined necessary by the Government. The Contractor shall identify how it will coordinate with the incoming contractor and/or Government personnel to transfer knowledge, including but not limited to, the following:

- Project management processes
- Points of contact
- Location of technical and project management documentation
- Status of ongoing technical initiatives
- Appropriate contractor-to-contractor coordination to ensure a seamless transition
- Transition of key personnel (if applicable)
- Schedule and key milestones for transition
- Actions required of the Government to facilitate transition

CDRL A015 Phase-Out Transition Plan / DI-MGMT-81945A

4.2 ADCP Technical Baseline Management

Deliverables are defined as the completion and acceptance according to the “Definition of Done” of the features completed, which are based on the contractor’s Agile Software Development methodology. This methodology defines the repeatable process of providing development outcomes in small iterations which results in the delivery of design, usable software, data, or product, which have little to no inherent defects from the intended implementation. Each outcome shall be defined as Functional Requirements by mutual agreement of the Government and contractor through consistent engagement per Agile Methodology. Functional Requirements shall enforce adherence to the contractor’s Agile Methodology rather than dictate the implementation specifics of a Feature. Adherence to the contractor’s Agile Methodology shall result in features that meet the Government’s capability requirements and objectives. Each feature shall document how planning, requirement analysis (user story building), design, coding, testing, quality assurance, and documentation shall all meet the contractor’s “Definition of Done.”

Functional Requirements for each feature, translated into Epics and User Stories shall be used to populate the Product Backlog shall include, but are not limited to:

- Initial application design and implementation
- User research and interviews
- System configuration to support business processes

- Integration for input and output methods
- Workflow design and implementation
- Overall collaboration of applications
- Enhancements, patches, and updates to applications, data, or cloud systems
- Data import of records collected from legacy systems
- Automated testing
- Updating user guides and assessing the impact on existing training material
- User Acceptance Testing

4.3 Product Roadmaps

The contractor shall develop quarterly updates of ADCP product roadmaps, and present at a quarterly roadmap review. Quarterly roadmaps subject to Government review/approval.

CDRL A011 Product Roadmap / DI-IPSC-82297

CDRL A012 Product Backlog / DI-IPSC-82298

The contractor shall support and participate in Government-led annual ADCP product roadmap reviews. Annual roadmap review outcomes shall be reflected in subsequent contractor developed and maintained product roadmaps.

4.4 Surge Capacity

The Contractor shall have the ability to expand its team quickly to meet an increased demand for services in the event of an emergent requirement or other need per TO. Effective surge capacity requires the coordination of multiple resources to mobilize staff and, in some cases, coordinate with outside resources to fulfill a need. The contractor shall have a surge capacity methodology that discusses a way to diffuse an increased need for personnel within a stated amount of time deemed reasonable by the Government. Any surge capacity issues shall be addressed and/or negotiated through the CO and will be incorporated by TO modification, if needed.

5.0 Contract Data Requirements List (CDRL)

The contractor shall deliver the CDRLs outlined within this TO PWS along with those identified at the ID/IQ level, when applicable or requested by the Government, as described in Exhibit A

6.0 Service Delivery Summary (Quality Control)

The Government will evaluate the contractor's performance under this TO IAW the Service Delivery Summary (SDS). The SDS outlines the plan to properly surveil the contractor's performance and ensure all objectives are met based on the PWS. Service requirements are summarized into Performance Objectives (PO's) that relate directly to mission essential items. The performance threshold briefly describes the minimum acceptable levels of service required for each requirement. The following PO, Measures and Thresholds will be implemented in order for the Government to properly

survey contractor performance and provide a method to evaluate the contractor's performance. The SDS represents performance metrics from the IDIQ PWS SLAs paragraph 4.3.4.

SDS	Performance Objective	PWS Para.	Performance Threshold	Surveillance Method	Remedy
01	Incident-Priority 1 Restoration (Mission Critical)	ID/IQ 4.3.4	≥ 95% within 2 hours' time to restore the functionality of systems, through addressing the root cause or implementing a work around	Observation and Surveillance	Possible reduction in any incentive fees CPARS
02	Rood Cause Analysis Remediation	ID/IQ 4.3.4	≥ 95% all remediation actions by building a culture of prevention	Observation and Surveillance Reporting period - monthly	Possible reduction in any incentive fees CPARS
03	Disaster Recover (DR)-RPO	ID/IQ 4.3.4	Less than 15 minutes but no longer than 1 hour for all applications and platforms to include the amount of data lost	Observation and Surveillance	Possible reduction in any incentive fees CPARS
04	Security Patch Management	ID/IQ 4.3.4	Critical: ≥ 99% of patches within the allotted time	Observation and Surveillance	Possible reduction in any incentive fees CPARS
05	Critical System Stability	ID/IQ 4.3.4	Number of unplanned outages to identified Critical Systems ≤ 1 per reporting period	Observation and Surveillance Reporting period – monthly	Possible reduction in any incentive fees CPARS
06	Critical System Reliability	ID/IQ 4.3.4	No unplanned outages for the identified Critical System for the reporting period	Observation and Surveillance Reporting period – monthly	Possible reduction in any incentive fees CPARS
07	Disaster Recover (DR) - RTO	ID/IQ 4.3.4	Ability to recover the systems in the event of a disaster with all systems functional and effectively working. ≤ 8 hours for Critical Systems; ≤ 24 hours for non-Critical Systems; ≤ 72 hours for all remaining systems covered by DR	Observation and Surveillance	Possible reduction in any incentive fees CPARS
08	Timeliness – Data Backup	ID/IQ 4.3.4	99.5% of all backups completed successfully within the backup window free from errors and omissions	Observation and Surveillance	Possible reduction in any incentive fees CPARS
09	Instance Availability (IaaS)	ID/IQ 4.3.4	The percentage of time the instance is available for normal business operations is ≥ 99.90%	Observation and Surveillance	Possible reduction in any incentive fees CPARS
10	Platform Availability (PaaS)	ID/IQ 4.3.4	Percentage of actual uptime with planned uptime for each application is 99.90% to 99.99%	Observation and Surveillance Reporting period – monthly	Possible reduction in any incentive fees CPARS

11	Critical Segment/Location Stability	ID/IQ 4.3.4	≤ 1 unplanned outage for the same Critical System during the reporting period	Observation and Surveillance Reporting period - monthly	Possible reduction in any incentive fees CPARS
12	Critical System Reliability	ID/IQ 4.3.4	No unplanned outages for the same Critical System in consecutive reporting periods	Observation and Surveillance Reporting period - monthly	Possible reduction in any incentive fees CPARS
13	Guaranteed Mean time to Repair/Restore	ID/IQ 4.3.4	Less than 8 hours for critical systems; 24 hours for non-critical systems and; 72 hours for remaining systems covered	Observation and Surveillance	Possible reduction in any incentive fees CPARS
14	Monitoring Availability	ID/IQ 4.3.4	The contractor's monitoring platform used to detect, diagnose, respond, track, and report service status and events is required for managed WAN services. Monitoring availability = 100%	Observation and Surveillance	Possible reduction in any incentive fees CPARS
15	SIEM Use Case Refresh Rate	ID/IQ 4.3.4	Percentage of SIEM Use Cases $\geq 10\%$ of the total number of Use Cases in the SIEM refreshed each month	Observation and Surveillance Reporting period – monthly	Possible reduction in any incentive fees CPARS
16	Testing of Vulnerabilities and Penetration Service Level	ID/IQ 4.3.4	Parameter to measure for all testing for vulnerabilities and penetration schedules = 100%	Observation and Surveillance	Possible reduction in any incentive fees CPARS
17	Priority 1 Security Incident	ID/IQ 4.3.4	Percentage of Severity 1 security incidents contained $\geq 95\%$ within 1 hour	Observation and Surveillance	Possible reduction in any incentive fees CPARS
18	Critical SLAs missed	ID/IQ 4.3.4	Measures the number of critical SLAs missed by the contractor during the reporting period ≤ 1 critical	Observation and Surveillance Reporting period - monthly	Possible reduction in any incentive fees CPARS
19	KPIs missed	ID/IQ 4.3.4	Measures the number of promotable KPIs missed by the contractor during the reporting period ≤ 3	Observation and Surveillance Reporting period - monthly	Possible reduction in any incentive fees CPARS
20	Cloud instances under management	ID/IQ 4.3.4	Infrastructure and Platform Services managed within scope of FinOps deliverables = 95% of cloud instances	Observation and Surveillance	Possible reduction in any incentive fees CPARS
21	24/7/365 Support	TO 3.3.6	The contractor shall include 24/7/365 support with 15-minute time to keyboard for platform incidents across all classifications during an incident is required.	Observation and Surveillance	Possible reduction in any incentive fees CPARS

22	24/7/365 Support	TO 3.3.6	The contractor shall provide 15-minute acknowledgement of a reported incident.	Observation and Surveillance	Possible reduction in any incentive fees CPARS
23	24/7/365 Support	TO 3.3.6	The contractor shall surge to meet 24/7/365 operational requirements during planned on-call windows, and as required by the Government per mission requirements.	Observation and Surveillance	Possible reduction in any incentive fees CPARS
24	24/7/365 Support	TO 3.3.6	The contractor shall provide 24/7/365 support for, and management of the platform deployed by the contractor to cloud and supporting pipelines.	Observation and Surveillance	Possible reduction in any incentive fees CPARS
25	24/7/365 Support	TO 3.3.6	The contractor shall provide 24/7/365 support for, and management of CSP services and BBaaS platform provided services (e.g., Gitlab, Nexus, Vault, ArgoCD, IdAM/Keycloak, Istio, etc.)	Observation and Surveillance	Possible reduction in any incentive fees CPARS
26	Data Deliverables	TO 5.0	The contractor shall provide CDRLs IAW with Exhibit A	Performance is acceptable when CDRLs are provided IAW with Exhibit A, delivered on time and accurate. There is no more than one (1) late document per quarter and no more than one (1) set of corrections/edits per document. Performance is unacceptable when CDRLs are not provided IAW with Exhibit A, are not on time and are inaccurate. If there is more than one (1) late document per quarter and more	Re-performance of work; CPARS Documentation

				than one (1) set of corrections/edits per document.	
--	--	--	--	---	--